Lecture Notes S03: Hạ tầng CA Phân tầng, Quy chế CP/CPS & Cấp phát Tự động ACME

Học phần: Cơ sở hạ tầng khóa công khai (ATHK 512) · Lớp CHAT4P
Giảng viên: Nguyễn An Khương (Khoa Khoa học & Kỹ thuật Máy tính, Trường ĐHBK Tp. HCM)
Trợ giảng: Nguyễn Hữu Hoàng Huy

---

1. Thiết kế Phân tầng CA và Giới hạn Đường dẫn (Path Length Constraint)

Khi xây dựng CA trung gian, cờ `basicConstraints` có tham số `pathlen` xác định số cấp CA con được phép tồn tại phía dưới: * `basicConstraints = critical, CA:TRUE, pathlen:0` $ightarrow$ Intermediate CA này chỉ được phép ký cấp phát cho thực thể đầu cuối (End-Entity), tuyệt đối không thể ký tạo thêm một CA con nào khác. * Kỹ thuật này ngăn chặn hoàn toàn rủi ro một CA trung gian bị lạm quyền để tạo ra các CA con không kiểm soát được.

---

2. So sánh Các Phương thức Thử thách Xác thực trong ACME

Loại Thử thách	Cơ chế Hoạt động	Ưu điểm Kỹ thuật	Nhược điểm & Hạn chế
HTTP-01	Máy chủ ACME truy vấn tệp ngẫu nhiên tại `http://<domain>/.well-known/acme-challenge/<token>`	Dễ triển khai, chỉ cần cấu hình máy chủ Web	Cần mở cổng 80 công khai; không hỗ trợ cấp phát chứng chỉ Wildcard (`*.kma.internal`)
DNS-01	Tạo bản ghi TXT tại `_acme-challenge.<domain>` chứa mã băm xác thực	Hỗ trợ cấp chứng chỉ Wildcard; không cần máy chủ mở cổng mạng công khai	Cần cấp quyền truy cập API DNS; độ trễ cập nhật truyền bá bản ghi DNS
TLS-ALPN-01	Bắt tay TLS sử dụng giao thức ALPN riêng biệt `acme-tls/1` trên cổng 443	Hoạt động trực tiếp trên cổng HTTPS; phù hợp thiết bị cân bằng tải	Cấu hình phức tạp hơn; cần can thiệp tầng xử lý bắt tay TLS

---

3. Khung Cấu trúc 9 Phần của CP/CPS theo RFC 3647

Một tài liệu CP/CPS chuẩn quốc tế bao gồm đúng 9 mục chuẩn mực: 1. *Introduction:* Định danh tài liệu, phạm vi áp dụng, thông tin liên hệ. 2. *Publication and Repository Responsibilities:* Trách nhiệm công bố chứng thư và danh sách thu hồi. 3. *Identification and Authentication:* Quy trình xác minh nhân thân cá nhân / máy chủ. 4. *Certificate Life-Cycle Operational Requirements:* Vòng đời yêu cầu, cấp phát, gia hạn, thu hồi. 5. *Facility, Management, and Operational Controls:* An ninh vật lý, quản lý nhân sự, lưu trữ nhật ký. 6. *Technical Security Controls:* Quản lý khóa mật mã (Key Pair Generation and Installation). 7. *Certificate, CRL, and OCSP Profiles:* Đặc tả định dạng chứng thư, các trường mở rộng OID. 8. *Compliance Audit and Other Assessments:* Quy trình thanh tra, kiểm toán định kỳ. 9. *Other Business and Legal Matters:* Trách nhiệm pháp lý, quyền riêng tư, giải quyết tranh chấp.

4. Tài liệu Tham khảo Mở rộng

1. **RFC 3647:** *CP/CPS Framework*. rfc-editor.org/rfc/rfc3647
2. **RFC 8555:** *ACME Protocol*. rfc-editor.org/rfc/rfc8555
3. **CA/Browser Forum Baseline Requirements v2.0.**